AI Agent Offboarding Checklist

Retire agents completely, starting with their triggers, not just their keys

Nexus Security Advisors · November 2026

Why this exists

When an employee leaves, you collect the laptop, turn off the badge, and disable the accounts. When an AI agent's pilot ends, usually nothing happens. It goes quiet, still connected, and still holding its keys.

Dormant is not the same as off. An agent that "just went quiet" keeps every credential and connection it was given, and anyone who can trigger it can reuse that access. OWASP ranks Improper Offboarding as the number one non-human identity risk (NHI1:2025).

> **The data:** in Arrakis Security's 2026 sample of production agents, 76% had not run in 60 days, 70% connected to at least one sensitive integration, and 19% used keys or tokens that never expire. About a quarter of dormant agents could still be started through an unsigned webhook. In Pax8's 2026 survey, 35% of small businesses found AI running without approval in the past six months.

How to use it: start this checklist as soon as any trigger below fires, without waiting for the next review. Work the steps in order. The agent owner and security both sign off at the end.

> **Companion document:** this is one half of a pair. Use it with the AI Agent Onboarding Checklist from Nexus Security Advisors. Both are free at nexussecurityadvisors.com/checklists.

When to offboard

Trigger	Who starts it	Timing
Pilot or project ends	Agent owner	At project close
Owner leaves or changes role	HR or IT, as part of the person's offboarding	Same day as the person
No run in 60 days and no justification from the owner	Security or IT	Within 5 business days
Security incident or suspected compromise	Security	Immediately: kill switch first, then offboard
Vendor, platform, or model retired or replaced	Agent owner	Before the cutover
Purpose or data scope changes significantly	Agent owner	Retire the old agent and re-onboard as new

> **The trigger most often missed:** the owner leaving. When a person is offboarded, check the register for every agent they own and every agent running on their OAuth grant. Microsoft Entra, for example, can now transfer agent sponsorship to the manager as part of a leaver workflow.

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Offboarding: retiring the agent completely

Offboarding record			
Agent name		**Risk tier**	
Owner		**Trigger**	
Started		**Target close**	

Work in this order. Disabling triggers first stops a dormant agent from being woken while you clean up.

Done	Checklist item	Owner	Date
1. Stop it from running			
☐	Disable every trigger: schedules, webhooks, event subscriptions, and calls from other agents		
☐	Disable or pause the agent itself on its platform		
2. Remove its access			
☐	Revoke and delete its API keys and tokens. Do not just let them expire		
☐	Revoke OAuth grants it holds, including any running on a person's account		
☐	Disable or delete its service account or non-human identity		
☐	Disconnect it from every integration in the register		
☐	Search config files, repos, prompts, tickets, and wikis for copies of its keys, and rotate any secret it shared with another system (MITRE ATLAS AML.T0083)		
3. Check for dependencies			
☐	Confirm no production workflow, report, or other agent still relies on it		
☐	Check agents that called this one: confirm whether they now fail, fall back, or route somewhere else		
☐	Notify the teams that used it		
4. Handle its data			
☐	Decide for memory, vector stores, prompts, files, and logs: keep, archive, or delete, following retention policy and legal holds		
☐	Confirm deletion with the vendor where data is hosted on their platform		
☐	Keep the audit logs for the full retention period, even if everything else is deleted		
5. Verify and close			
☐	Test that the agent can't be started, its old webhook URLs fail, and its credentials no longer work		

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Done	Checklist item	Owner	Date
☐	Update the register: status retired, date, and who signed off		
☐	Owner and security both sign off on the closure		

Closure sign-off			
Agent owner		**Date**	
Security		**Date**	
Data decision by		**Register updated**	

Common offboarding scenarios

Scenario	Risk if skipped	Key steps
Pilot ends for a help desk or reporting agent	Agent stays published with access to sensitive records and nobody watching	Steps 1, 2 and 5; data decision on memory
Contractor or employee who built automations leaves	Workflows break when their grant is revoked, or keep running on a dead account	Move needed workflows to a service identity first, then revoke grants
Agent compromised or behaving unexpectedly	Attacker keeps access through triggers or copied keys	Kill switch, then full offboarding with a credential sweep
Vendor retires a model or platform	New agent goes live while the old one keeps its keys and webhooks	Offboard the old agent before cutover
Customer-facing agent retired	Memory and vector stores keep customer data after retirement	Data decision with a named approver; vendor deletion confirmed

What can go wrong with offboarding

What goes wrong	How it shows up	How to head it off
Offboarding a person breaks production	Revoking a leaver's OAuth grant silently kills workflows that ran on it	Check the register before the leaver's accounts close; move agents to a service identity first
Agent disabled, triggers left on	A webhook or schedule wakes the agent, or a copy of it, weeks later	Disable triggers first; test that old webhook URLs fail
Keys revoked, copies survive	The same secret sits in a config file, repo, ticket, or another tool and still works there	Credential sweep; rotate shared secrets rather than deleting only the agent's copy
Delegation chains outlive the agent	A downstream agent keeps running a task the retired agent started, under its own credentials	Check callers and callees using the register
Data deleted that had to be kept	Memory or logs wiped while under legal hold or a retention requirement	Legal and records check before deletion

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

What goes wrong	How it shows up	How to head it off
Sensitive data kept that should be gone	Vector stores and memory keep PII, credentials, or client data	Named approver for the data decision; verify vendor-side deletion
Nobody signs off	Register still shows the agent as active, so the next review wastes time or misses it	Closure is not done until owner and security both sign

Pros and cons of formal offboarding

Benefits	Costs and trade-offs
Removes standing access that attackers can reuse through dormant agents	Takes time from owners who have moved on to other work
Cuts license, token, and API spend on idle agents	Risk of breaking a hidden dependency if the dependency check is rushed
Produces clean audit evidence of account removal (AC-2, ISO 27001 5.18)	Some platforms can't fully delete agent data or prove deletion
Keeps the register accurate, so reviews get faster over time	Strict dormancy rules can catch seasonal agents unless they are tagged

Framework mapping

Mapped at the control family level. Check exact control IDs against your own scope.

Framework	What it requires	Where it shows up
NIST SP 800-53 Rev. 5, AC-2	Defined account owners, approval, periodic review, and disabling accounts that are no longer needed	Triggers, removal, sign-off
NIST AI RMF 1.0	Accountability, an inventory of AI systems, and safe decommissioning (Govern, Map, Manage)	Decommissioning
ISO/IEC 42001:2023	An AI management system covering the full AI life cycle, including retirement	Retirement stage
ISO/IEC 27001:2022 Annex A (5.15, 5.16, 5.18, 8.2, 8.5)	Access control, identity management, provisioning and removal of access rights, privileged access, secure authentication	Removal of access rights
OWASP Non-Human Identities Top 10 (2025)	NHI1 Improper Offboarding, NHI5 Overprivileged NHI, NHI7 Long-Lived Secrets, NHI9 NHI Reuse, NHI10 Human Use of NHI	The whole checklist (NHI1)
OWASP Top 10 for Agentic Applications 2026	ASI03 Identity & Privilege Abuse, ASI04 Agentic Supply Chain, ASI06 Memory & Context Poisoning, ASI10 Rogue Agents	Rogue and orphaned agents
MITRE ATLAS AML.T0083	Adversaries harvest API keys and tokens stored in agent configuration files	Credential sweep

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Sources

- Forgotten AI agents may still access sensitive company data, Help Net Security on the Arrakis Security 2026 Autonomous Agents Threat Report (vendor telemetry from thousands of production agents over 12 weeks), October 26, 2026.
- Pax8 Research Finds Small Businesses Are Building AI Faster Than They Can Govern It, Pax8 Q3 2026 SMB AI Pulse Report, 1,150 small business leaders in the US, UK, Germany, and Sweden, October 2026.
- OWASP Top 10 Non-Human Identities Risks (2025), OWASP Foundation.
- OWASP Top 10 for Agentic Applications for 2026, OWASP GenAI Security Project, December 2025.
- LLM06:2025 Excessive Agency, OWASP Top 10 for LLM Applications 2025.
- Careful Adoption of Agentic AI Services, CISA, NSA, and partner agencies from Australia, Canada, New Zealand, and the UK, May 1, 2026.
- AML.T0083 Credentials from AI Agent Configuration, MITRE ATLAS.
- NIST SP 800-53 Rev. 5, NIST AI RMF 1.0, NIST CSF 2.0, and ISO/IEC 42001:2023.

Additional resources

- Accelerating the Adoption of Software and AI Agent Identity and Authorization, NIST NCCoE concept paper, February 2026. Where federal guidance on agent identity, authorization, and non-repudiation is heading.
- Agentic AI Identity and Access Management: A New Approach, Cloud Security Alliance, August 2025. A reference architecture for agent identity in multi-agent systems.
- Agent identity sponsor tasks in Lifecycle Workflows, Microsoft Learn. Moves agent sponsorship automatically when the human sponsor changes roles or leaves.
- Nexus Security Advisors readiness checklists, including AI governance, CMMC, HIPAA, SOC 2, and cyber insurance.

A note on the numbers: the Arrakis figures come from the vendor's own customer telemetry and the Pax8 figures from a vendor-run survey. Treat them as useful signals, not independent research, and check them against your own register before they go in front of a board.

Need help standing this up? Nexus Security Advisors helps growing businesses put AI governance in place without slowing adoption. Request a consultation.

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.